arXiv:2610.28430v1 [cs.CR] 20 Oct 2026

A Digital Twin to Improve Cyber-Social Impact

Vita Santa Barletta[1 [0000−0002−0163−6786]], Danilo Caivano[1 [0000−0001−5719−7447]], Gabriel Cellammare[1,2 [0009−0001−1570−4487]], Andrea Dimauro[1 [0009−0004−2137−9547]], Pasquale Mesagna[3 [0009−0005−6479−6364]], and Massimiliano Morga[4 [0009−0005−9558−6888]]

[1] University of Bari Aldo Moro
[2] IMT School for Advanced Studies Lucca
[3] Sapienza University of Rome
[4] SER&Practices
{vita.barletta,danilo.caivano}@uniba.it, gabriel.cellammare@imtlucca.it, andreadimauro2001@gmail.com, mesagna.2260332@studenti.uniroma1.it, m.morga@serandp.com

Abstract. The increasing complexity of Industrial Control Systems (ICS) and their integration with IT infrastructures has significantly expanded the cyber threat landscape. Traditional cybersecurity models, primarily based on the Confidentiality, Integrity, and Availability (CIA triad), fail to capture the broader societal and operational impacts of cyber-attacks. This paper proposes a novel framework that integrates Digital Twin technology with a Cyber-Social Security model to simulate, analyze, and quantify cyber threats in critical infrastructures. Virtualized ICS environments built with Mininet and MiniCPS are used to model attack scenarios and assess their consequences across technical and social dimensions. At the core of the framework lies the Cyber-Social Vulnerability Scoring System (CSVSS), a quantitative metric that extends CVSS with a Social Impact dimension grounded in the Entity and Place pillars, producing a single, reproducible severity score that reflects real-world consequences. Crucially, the framework does not automate risk assessment but keeps the human analyst at its center: a Large Language Model (LLM) performs a first-pass analysis – mapping vulnerabilities and drafting risk reports – while the analyst, supported by explainable AI feedback, validates the findings and retains decision authority over critical cases. Experimental results demonstrate the framework's ability to model and score cyber-social impact, while the human-in-the-loop design is presented as a conceptual principle to preserve oversight.

Keywords: Digital Twin · Cyber-Social Security · ICS.

1 Introduction

Industrial Control Systems (ICS) play a crucial role in managing critical infrastructure, including energy, transportation, and smart cities. However, their

increasing interconnection with IT systems has introduced significant cybersecurity challenges. ICS environments are characterized by legacy protocols, limited security mechanisms, and high availability requirements [1]. Protocols such as Modbus lack encryption and authentication, making them particularly vulnerable to cyberattacks [2]. Consequently, securing ICS and Operational Technology (OT) environments is crucial, as successful attacks can disrupt operational continuity, essential services, and human safety.

Traditional cybersecurity assessment relies on the CIA triad (Confidentiality, Integrity, Availability). Vulnerability severity is commonly quantified using the CVSS (Common Vulnerability Scoring System) [3,4], which assesses exploitation conditions and technical impacts on CIA properties. However, this approach remains focused on the technical domain and does not account for broader sociotechnical consequences, such as cognitive manipulation, information degradation, loss of trust, or cascading effects across interconnected social and physical systems. To address this gap, the concept of Cyber-Social Security (CSS) [5] extends cybersecurity analysis beyond technical infrastructures by considering four interconnected domains: *cyber*, *physical*, *informational*, and *cognitive*. These domains capture how cyber threats propagate and affect individuals, organizations, and society. This paper proposes a framework that integrates Digital Twin technology with a Cyber-Social Security model to address these limitations. The Digital Twin replicates complex cyber-physical networks, enabling researchers to study and assess the effects of potential cyberattacks not only on systems and data but also on individuals, organizations, locations, and broader ecosystems. The main contributions are: (i) a *Cyber-Social Impact Model (CIAEP)* that extends the CIA triad with the Entity and Place dimensions ; (ii) the *Cyber-Social Vulnerability Scoring System (CSVSS)*, an extension of CVSS v3.1 that incorporates the new dimensions into a unified severity score; (iii) a *Digital Twin framework* supported by a human-in-the-loop analysis process, where a Large Language Model assists analysts in vulnerability mapping and risk-report generation while preserving human decision authority. The paper is structured as follows. Section 2 reviews Digital Twin approaches for cybersecurity. Section 3 presents the proposed framework and CSVSS metric. Section 4 describes the Digital Twin architecture, while Section 5 introduces the attack scenarios. Section 6discusses the experimental results, and Section 7 concludes the paper and discusses directions for future research.

2 Related Work

Digital Twins (DTs) have been increasingly adopted to improve cybersecurity in Industrial Control Systems (ICS), IoT networks, smart grids, automotive systems, and smart cities. A common approach combines physics-based or data-driven simulations with machine learning techniques for anomaly detection, enabling proactive security monitoring and safe attack experimentation [1].

Several studies demonstrate the effectiveness of DTs for intrusion detection. Varghese et al. [6] developed a DT of an industrial filling plant integrated with

a stacked ensemble classifier capable of detecting process-aware attacks in near real time. Similarly, Sayghe [7] applied a DT to a water-treatment SCADA system, achieving high detection accuracy against false data injection, DoS, and command injection attacks. El-Hajj [8] combined Eclipse Ditto and Snort in a DT-based testbed, showing effective detection of flood attacks, although reconnaissance scans remained challenging. Beyond intrusion detection, DTs are increasingly used for attack simulation and threat intelligence generation. Dietz et al. [9] leveraged ICS digital twins to execute attack scenarios and automatically produce Cyber Threat Intelligence (CTI) reports in STIX2.1 format. In the automotive domain, Venkatachalapathy [10] used DTs to replicate attack scenarios and analyze vulnerabilities in connected vehicle systems.

Complementary efforts focus on DT-based testbeds. GRFICSv2 [11] provides a realistic ICS environment supporting representative attacks such as Modbus ARP spoofing and PLC code injection. However, its fixed architecture limits the modeling of heterogeneous scenarios. Recent research further highlights the role of DTs in smart cities, where high-fidelity virtual models enable cybersecurity experimentation without affecting operational infrastructures [12].

Despite these advances, securing ICS environments remains challenging. Most existing solutions are adapted from traditional IT security and do not fully address the operational constraints and unique characteristics of ICS environments [2]. Consequently, many conventional security mechanisms cannot be directly deployed without affecting performance or availability.

These limitations motivate the development of flexible and programmable DT frameworks – such as the Mininet[5] and MiniCPS[6] – adopted in this work, capable of modeling heterogeneous cyber-physical infrastructures and supporting the analysis of cyber-social consequences across different operational scenarios.

3 Proposed Approach

This work proposes a framework that couples Digital Twin (DT) technology with a Cyber-Social Security model to simulate, analyze, and quantify cyber threats in Industrial Control Systems (ICS) and cyber-physical environments.

Cyber-Social Impact Model. The CIA triad addresses the technical properties of a resource but is silent on *who* and *what* are ultimately harmed by exploiting a vulnerability, affecting not only data protection but also physical protection and digital lives. We therefore extend the triad with two dimensions: *Entity (E)*: the people, organizations, and operational roles affected by an attack. A compromise affects not only data but the individuals and institutions that depend on it; *Place (P)*: the physical or digital location of the affected information and processes. The same attack can stay local or escalate to critical infrastructure, cities, regions, or even geopolitical factors. For example, to illustrate the distinction, consider a ransomware attack that encrypts the HMI of an

[5] https://github.com/mininet/mininet
[6] https://github.com/scy-phy/minicps

energy plant. The *Entity* dimension captures *who* is harmed – the control-room operators who lose access, the operating organization, and ultimately the citizens depending on the service – whereas the *Place* dimension captures *how far* the effect propagates – from the local HMI node to the critical energy infrastructure and, potentially, to an entire region.

Evaluation of Cyber-Social Impact in Smart City. The Cyber-Social Impact Model extends traditional cyber-physical analysis through the Entity and Place dimensions, enabling the assessment of attack effects across interconnected social and spatial scales. To capture the complexity of modern socio-technical environments, the model is instantiated within a Smart City ecosystem [13], where digital technologies support urban services, sustainability, and quality of life. As shown in Fig. 1, the Smart City is described along two axes: a *horizontal dimension*, representing the technological layers (network infrastructure, sensors and devices, management platforms, and applications), and a *vertical dimension*, representing the main urban domains (people, energy, economy, mobility, and livability). A cyberattack originating in one technological layer may propagate across multiple domains, thereby acquiring a cyber-social impact.

The consequences of an attack are further analyzed through four complementary dimensions: *cyber* (systems and services affected), *informational* (information flows and narratives), *physical* (infrastructure and operational processes), and *cognitive* (human perception, trust, and decision-making). Together, these dimensions enable a unified assessment of technical, informational, physical, and human consequences. However, both CVSS and CIAEP remain fundamentally static models. After each simulation, the affected assets and domains must be identified manually, a process that becomes increasingly complex and time-consuming when analyzing large numbers of attack scenarios within a Digital Twin environment.

Cyber-Social Vulnerability Scoring System. CVSS v3.1 derives a Base Score from three impact metrics (C, I, A) combined with exploitability metrics, but it remains confined to the technical sphere. CSVSS maintains the structure of CVSS v3.1 and adds the Social Impact (SI) dimension as a fourth impact metric, ensuring the final value reflects the social dimension while remaining conceptually and mathematically close to the standard. To remove the subjectivity noted in qualitative impact tables, we define explicit anchors for the Entity and Place levels and a deterministic rule that maps them to the scoring system's numeric scale (Table 1). Both dimensions are rated on the same three-valued scale adopted by CVSS v3.1 impact metrics: *None* (0), *Low* (0.22) and *High* (0.56).

The two dimensions are aggregated into a single *Social Impact* (SI) value that feeds the scoring formula. To avoid underestimating social exposure, we adopt a conservative worst-case aggregation:

$$\mathrm{SI} = \max(\mathrm{E}, \mathrm{P}) \tag{1}$$

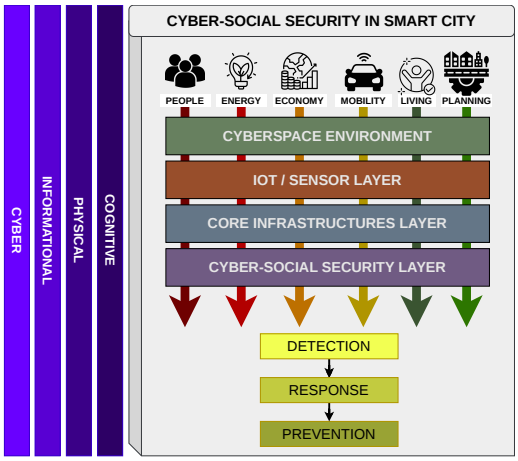

Fig. 1. Cyber-Social Security framework for smart cities linking urban domains, technology layers, and cyber-physical-informational-cognitive impacts

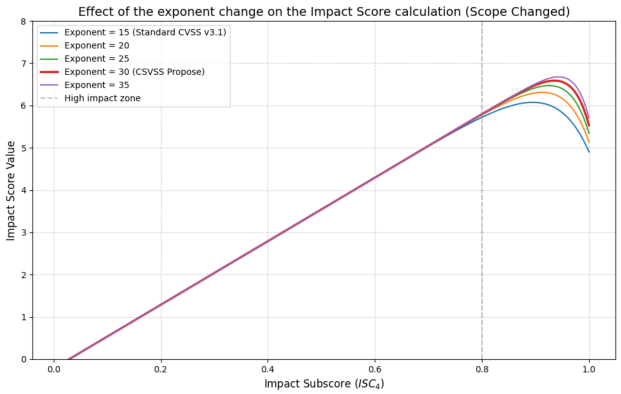

Fig. 2. Calibration of the CSVSS corrective term for different exponent values. The comparison highlights how n=30 provides improved discrimination at high-impact levels while preserving monotonicity and maintaining consistency between technical severity and socio-technical consequences.

Table 1. Assignment criteria for the Entity (E) and Place (P) dimensions.

Level	Entity (E)	Place (P)
None (0)	No human or organizational party affected.	No spatial propagation.
Low (0.22)	A bounded set of individual users; recoverable; no sensitive credentials or safety roles involved.	Effect confined to a single node or local segment.
High (0.56)	Many users/operators, or safety-relevant personnel ,and critical organizational roles, sensitive credentials or personal data exposed.	Propagation to critical infrastructure, multiple smart cities domains, or a regional scale.

which keeps SI within the admissible CVSS set $\{0, 0.22, 0.56\}$ and preserves mathematical compatibility with the standard.

All symbols in the equations below follow the CVSS v3.1 Base specification, which builds the score from two metric groups. The *Impact* metrics describe the consequence on the affected component and comprise Confidentiality (C), Integrity (I) and Availability (A). To these, CSVSS adds the Social Impact (SI) of Eq. (1), and each of the four takes the value None = 0, Low = 0.22 or High = 0.56. The *Scope* (S) is a switch value: it is *Unchanged* when the exploit affects only resources under the security authority of the vulnerable component, and *Changed* when it breaches that authority and reaches a different one.

The *Exploitability* term, instead, measures how readily the vulnerability is reached and combines four metrics of the vulnerable component: Attack Vector (AV: Network 0.85, Adjacent 0.62, Local 0.55, Physical 0.20), Attack Complexity (AC: Low 0.77, High 0.44), Privileges Required (PR: None 0.85, Low 0.62, High 0.27 – raised to 0.68 and 0.50 when the Scope is Changed) and User Interaction (UI: None 0.85, Required 0.62).

The resulting four-pillar Impact Subscore is

$$\mathrm{ISC}_4 = 1 - \big[(1-C)(1-I)(1-A)(1-\mathrm{SI})\big] \tag{2}$$

As in the standard, the Impact depends on *Scope*:

$$\text{Scope Unchanged:} \quad \mathrm{Impact} = 6.42 \times \mathrm{ISC}_4 \tag{3}$$

$$\text{Scope Changed:} \quad \mathrm{Impact} = 7.52\,(\mathrm{ISC}_4 - 0.029) - 3.25\,(\mathrm{ISC}_4 - 0.02)^{30} \tag{4}$$

The Exploitability subscore is unchanged from CVSS v3.1:

$$\mathrm{Exploitability} = 8.22 \times \mathrm{AV} \times \mathrm{AC} \times \mathrm{PR} \times \mathrm{UI}. \tag{5}$$

Impact and Exploitability are combined into the final Base Score following the CVSS v3.1 specification:

$$\mathrm{BaseScore} = \begin{cases} 0, & \mathrm{Im} \le 0 \\ \mathrm{Roundup}(\min(x, 10)), & S{=}\mathrm{U} \\ \mathrm{Roundup}(\min(1.08\,x, 10)), & S{=}\mathrm{C} \end{cases} \tag{6}$$

where $x = (\text{Impact} + \text{Exploitability})$, while S=U and S=C denote an unchanged and a changed *Scope*, respectively and Im indicates the *Impact*. Scope and the cyber-social dimensions capture different aspects of an attack and are therefore assessed independently. Consistent with CVSS v3.1, Scope remains a purely technical attribute describing whether exploitation affects resources beyond the original security authority. In contrast, the Entity and Place dimensions measure the societal reach of the consequences, representing the breadth of affected actors and the spatial or operational extent of the impact.

As a result, these dimensions are not interchangeable. An attack may remain within a single security authority (*Scope: Unchanged*) while affecting a large number of individuals (*Entity: High*), or it may cross multiple security boundaries (*Scope: Changed*) but have limited societal impact (*Entity: Low*, *Place: Low*). Keeping these dimensions independent preserves compatibility with CVSS, avoids double-counting propagation effects, and enables a clearer distinction between technical spread and socio-technical consequences.

The only variation to the original CVSS formulation concerns the exponent used in the Scope-Changed impact function. CVSS v3.1 adopts an exponent of 15; however, because CSVSS aggregates four impact dimensions, high values of ISC_4 occur more frequently. In this case, the corrective subtraction term of Eq. (4) may excessively penalize the score, potentially producing a CSVSS value lower than the corresponding technical CVSS.

Figure 2 illustrates the calibration process. While an exponent of 15 introduces a strong curvature near maximum impact values, reducing score discrimination, an exponent of 30 preserves monotonicity and improves sensitivity in the upper severity range. This adjustment limits the effect of the corrective term and ensures greater consistency between technical severity and the broader socio-technical consequences captured by CSVSS.

Therfore, CSVSS is deliberately built on v3.1 and is *not* a re-implementation of CVSS v4.0 safety. CVSS v4.0 is the first version to account explicitly for Operational Technology and for vulnerabilities with physical *safety* implications through dedicated supplemental and environmental metrics [14]: the *Social Impact* dimension does not measure direct physical harm to a person or process, but the propagated *societal* consequence of an attack – continuity of essential services, public trust and social stability across smart-city domains. Safety and social impact are complementary lenses; CSVSS contributes the latter, which neither v3.1 nor v4.0 elevates to a first-class component of the score.

LLM-based Cyber Risk Analysis. To overcome the static, manual nature of the assessment described above, a Large Language Model (LLM) is integrated into the Digital Twin environment as its core intelligence layer, enabling dynamic, automated analyses (Fig. 3). Unlike traditional Machine Learning approaches, which rely on predefined features and structured datasets, LLMs enable semantic understanding and contextual reasoning over heterogeneous, unstructured data and can autonomously assess the impact of a cyber attack, reducing the time needed to evaluate results.

A general prompt is used across all simulations and then adapted to the specific cyberattack under consideration, possibly including the log files generated within the Digital Twin. The analysis follows a structured pipeline: (i) identification of attack patterns using the CAPEC taxonomy; (ii) mapping of vulnerabilities to CWE categories; (iii) assignment of severity scores using CVSS metrics; and (iv) generation of structured, explainable risk reports.

This pipeline yields automated, context-aware analysis of cyber threats, improving situational awareness and supporting decision-making, and it lets the LLM interpret cyber-physical interactions and their potential cyber-social impact, bridging technical analysis and real-world consequences. The feasibility of leveraging general-purpose generative AI for this task is supported by recent studies [15], which confirm that LLMs can automate vulnerability scoring by extracting context directly from textual descriptions, significantly reducing manual overhead. The adopted model is Mistral 7B [16], a 7-billion-parameter language model: despite its small size, it shows competitive performance among base models with fewer than 13 billion parameters and strong natural-language comprehension, which makes it well suited to automated, contextualized scientific analysis.

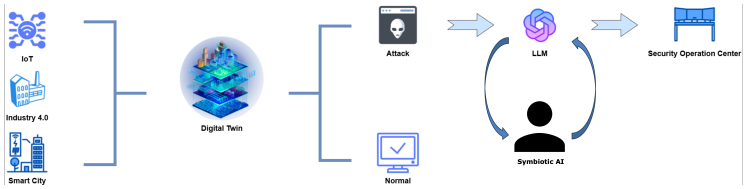

Fig. 3. Digital Twin framework for real-world systems: integrating IoT data, attack-/normal scenario detection, and LLM-driven symbiotic AI to support Security Operations Center decision-making and risk management.

Human-in-the-loop and Symbiotic Analysis. A design principle of the proposed framework is that the LLM is a symbiotic augmentation layer for the security analyst. This choice reflects the human-centered view that effective human-AI teams exploit the complementary strengths of each partner, letting automation handle routine, well-understood cases while analysts concentrate on tasks that require critical thinking and domain expertise [17]. Conceptually, the framework aligns with tiered-autonomy models of human-AI collaboration in security operations [18]: rather than a multi-level autonomy taxonomy, it proposes a single human-validation gate, in which the LLM operates with high autonomy on routine, low-criticality findings while critical cases are intended to be escalated to the analyst, who retains decision authority.

The expected division of tasks is: (i) *AI (implemented)*: synthetic-dataset generation, log triage, mapping of findings to CAPEC/CWE, first-pass CVSS assignment, and drafting of structured reports – the repetitive, high-volume work

that drives analyst fatigue; (ii) *Human (by design)*: validation of the AI output, contextual disambiguation, ethical and strategic judgment, and accountability for the final CSVSS verdict in critical scenarios.

This principle is motivated by measured LLM behaviour rather than by convenience: on the task of mapping vulnerabilities to CVSS metrics, recent large-scale evaluation shows that LLMs misclassify a non-negligible and correlated set of cases, and that ensembling yields only marginal gains [15].

4 Methodology

Digital Twin Architecture. The Digital Twin developed in this work is based on the combined use of Mininet and MiniCPS, enabling the creation of virtualized cyber-physical environments that replicate real-world infrastructures (Fig. 4). Mininet provides realistic network emulation, including hosts, switches, and communication links, while MiniCPS extends these capabilities by simulating physical processes and control systems typical of ICS environments [19, 20].

The architecture is organized into four main layers:

- *Data Collection and Acquisition*: This layer gathers data from physical devices, sensors, and simulated industrial components.
- *Data Management and Synchronization*: Responsible for handling data flows, ensuring consistency, and synchronizing system states.
- *Data Modeling and AI-driven Services*: Enables simulation, data processing, and advanced analysis through Large Language Models (LLMs), supporting semantic interpretation of events and automated report generation.
- *Data Visualization*: Provides interfaces for monitoring system behavior and analyzing results.

This layered architecture ensures modularity and adaptability, allowing the DT to be applied across different domains, including IT infrastructures, ICS, and smart city environments [13]. The framework was implemented on a moderate workstation (an AMD Ryzen 5700U CPU with 16 GB of DDR4 RAM), demonstrating that the DT does not require high-end hardware. The environment combines VirtualBox, hosting the Ubuntu virtual machine in which the DT runs; Mininet, for network emulation; MiniCPS, extending Mininet with the physical-process and control-logic simulation typical of ICS; and prompt engineering, used to generate the synthetic datasets that feed realistic data flows into the system.

The development of the proposed framework follows a structured methodology composed of two main phases:

1. *Digital Twin Design and Implementation.* In this phase, a virtual representation of a cyber-physical infrastructure is designed and implemented. The network topology, communication protocols, and system components are defined using programmable scripts, enabling flexible and reproducible configurations.

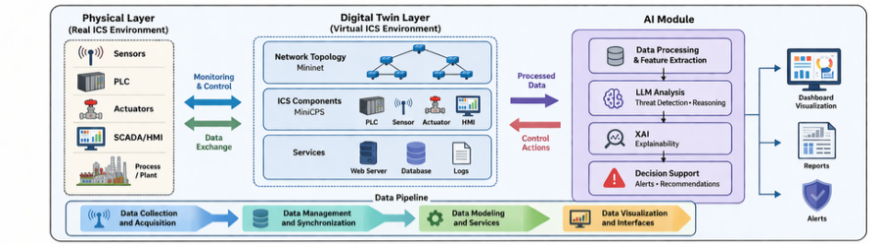

Fig. 4. Overall architecture of the proposed Digital Twin framework for ICS, integrating physical and digital layers with AI-based analysis.

2. *LLM-driven Analysis and Enhancement.* Large Language Models are integrated to perform semantic analysis of cyber events, correlate heterogeneous data sources, and generate structured security reports. Unlike traditional Machine Learning approaches, LLMs enable context-aware reasoning, improving the interpretation of complex attack scenarios and supporting the cybersecurity analyst.

This methodology allows for iterative refinement of the DT, progressively increasing the realism and complexity of simulated scenarios. Therefore, the proposed framework emphasizes flexibility, scalability, and realism. By combining network emulation, physical process simulation, and AI-driven analysis, the DT provides a comprehensive environment for cybersecurity experimentation.

Network Architecture of the DT. Industrial production is among the sectors most exposed to cyber threats, so the DT is instantiated over a concrete industrial scenario rather than a generic topology. The reference case is inspired by one of the major Italian operators in the energy and manufacturing sectors. The resulting network (Fig. 5) is a realistic but fictional industrial scenario that abstracts the key components. Aligned with Smart-Grid conceptual models [21], the design realizes the convergence of Information Technology (IT) and Operational Technology (OT) needed to support real-time management and the integration of renewable energy sources. This same IT/OT convergence, however, exposes previously isolated production systems to sophisticated attacks and introduces new critical vulnerabilities [22].

The topology is deliberately a *functional abstraction* rather than a faithful replica, for two reasons: first, to bound the simulation complexity, which grows rapidly with the number of nodes; second, to prioritize the generation of immediately analyzable data over detailed reproduction. On the IT side, the network comprises an SDN controller, a NAT/gateway, a switching fabric, a customer support server, and a Network Operations Center, while a VPN boundary separates it from the OT network and external customer access. This layout provides the substrate over which the simulated attacks propagate from the cyber domain into the smart-city Place dimension.

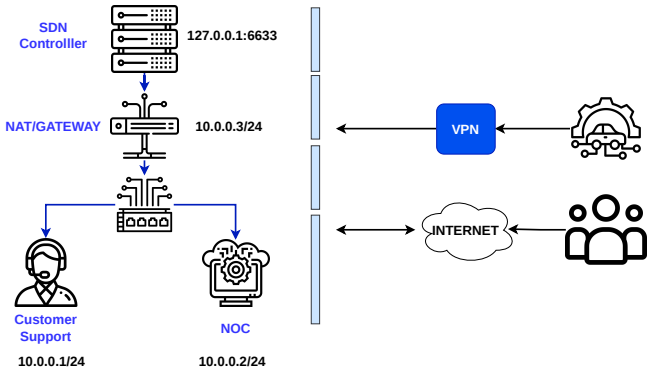

Fig. 5. Reference network architecture of the industrial Digital Twin (DT). The topology provides a functional abstraction of industrial environment, capturing the main IT and OT components, their interconnections, and the VPN boundary between the two domains. The architecture supports the simulation of cyber-attack propagation from the IT/OT infrastructure toward the smart-city Place dimension.

5 Attack Simulations

To assess both the resilience of the proposed architecture and the effectiveness of the CSVSS metric, four distinct attack scenarios were implemented within the Digital Twin. The scenarios were deliberately selected to target different layers of the IT/OT infrastructure, so as to observe both the technical degradation and the resulting social impact: (i) *Denial of Service (DoS):* targets the availability of the Customer support server by flooding the network with a high volume of packets, saturating system resources and allowing the resulting social disruption to be evaluated; (ii) *Cross-Site Scripting (XSS):* reproduces a Broken Access Control condition in the IT network that may lead to unauthorized access within essential service delivery. The choice of XSS is motivated by the high prevalence of this vulnerability class in web security [23]; (iii) *Ransomware:* models data encryption in order to capture the transition from a localized IT security event to a potential operational halt of essential services [24]; (iv) *Kurtlar.exe malware:* targets VNC management interfaces on ports 5800-5901, exploiting weak credentials to obtain remote control over OT stations and thereby assessing the risk of unauthorized command injection [7].

The outputs of these simulations were subsequently processed using an LLM-based analysis, which automates mapping observed vulnerabilities to the CWE and CAPEC taxonomies and computing the final scores.

[7] `https://www.dragos.com/ot-cybersecurity-year-in-review`

6 Results and Evaluation

This section reports the results obtained from the four attack scenarios defined in Section 5, executed within the proposed Digital Twin. The evaluation is organized into four parts: (i) the technical impact analysis, (ii) the cyber-social impact assessment, (iii) the quantitative evaluation through the CSVSS scoring model, and (iv) the LLM-based risk analysis.

Technical Impact Analysis. The experiments were carried out in the virtualized ICS environment based on Mininet and MiniCPS.

The flooding attack produced a marked degradation of service availability, with increased response times and intermittent disruptions in the *Denial of Service* attack. Resource utilization remains consistently high across iterations, confirming the attack's effectiveness in saturating the system's capacity. A representative entry from the server log produced within the DT is:

```
10.0.0.5 - - [08/May/2025 16:41:38] "GET / HTTP/1.1" 200 -
```

The success of the stored *Cross-Site Scripting* chain is documented by three logs. The attacker logs records the payload deployment; the web-server log then shows the injection (`POST /store_xss`) followed by two clients reaching the vulnerable endpoint; finally, the stolen-cookies log confirms that the payload executed on the clients, capturing session identifiers and user tokens that could be reused for session hijacking:

```
2025-05-16 17:38:26 - attacker - INFO - XSS attack payload deployed
10.0.0.3 - - [16/May/2025 17:38:26] "POST /store_xss HTTP/1.1" 302
10.0.0.5 - - [16/May/2025 17:38:29] "GET /vulnerable_endpoint HTTP/1.1" 200
10.0.0.5 - - [16/May/2025 17:38:30] "GET /vulnerable_endpoint HTTP/1.1" 200
Fri May 16 17:35:38 2025 - session_id=ADMIN_SESSION_123; user_token=ADMIN_SECRET_456
Fri May 16 17:38:29 2025 - session_id=DOWZANW9U8; user_token=ffxbdhvbq21xen2x
```

An initial OSINT phase revealed an SSH service on port 22 as a plausible entry point; the subsequent compromise (through unknown vulnerabilities or social engineering against the node operator) was treated as transparent and not implemented operationally, while the encryption stage was executed and measured. The resulting log shows 1002 test files encrypted in 0.16 s, for about 16 KB:

```
Timestamp, Enc Files, Size (bytes), Time (s)
2025-07-06 17:43:37, 1002, 15893, 0.16
```

Despite its small scale, the test illustrates how quickly ransomware can act once access is obtained: even a few seconds can cause considerable damage, even in environments equipped with modern defenses.

The simulation demonstrated how the malware Kurtlar.exe can compromise a vulnerable VNC service through brute-force attack, also producing failed attempts against other exposed services. The results of the attack were recorded in the following CSV:

```
timestamp, target_name, target_ip, password, result
2025-07-10 10:01:23, host1, 10.0.0.1, 12345, AUTH_FAILED
2025-07-10 10:03:23, host1, 10.0.0.1, 123, AUTH_SUCCESS
2025-07-10 10:02:05, host8, 10.0.0.8, 12345, AUTH_FAILED
2025-07-10 10:03:47, host5, 10.0.0.5, 123, AUTH_SUCCESS
```

Overall, these results confirm that the Digital Twin reproduces the behavior of the four attacks and their technical consequences in a realistic manner.

Cyber-Social Impact Assessment The simulated attacks originate in the cyber domain and initially affect the horizontal sensor and network layers of the smart-city architecture, propagating subsequently to vertical domains such as people, the economy, and livability. These cascading effects are interpreted within the Cyber-Social Security paradigm, which integrates both technical and societal perspectives. Accordingly, each scenario is evaluated using the CIAEP model which extends the CIA triad with Entity and Place dimensions.

From a *technical (CIA)* perspective, the DoS attack impacts only availability (C, I = None; A = High). The XSS attack compromises confidentiality through session hijacking and enables integrity violations via impersonation (C, I = High; A = None). The ransomware scenario affects all CIA dimensions through encryption and data exfiltration (C, I, A = High), while the Kurtlar.exe scenario compromises confidentiality, integrity, and availability by enabling full remote control of OT systems (C, I, A = High).

In the *Entity (E)* dimension, the DoS and XSS attacks remain limited to bounded sets of end-users or administrators with fully recoverable effects (E = Low). In contrast, ransomware and Kurtlar.exe impact safety-relevant operators, organizations, and dependent citizens (E = High). Regarding the *Place (P)* dimension, DoS and XSS remain confined to IT services and single web components (P = Low), whereas ransomware and Kurtlar.exe propagate to critical infrastructure and potentially regional-scale operational systems (P = High), with Kurtlar.exe additionally bridging IT, sensor, and OT layers.

The Detection–Response–Prevention lifecycle structures the security response across tactical and strategic levels by integrating these multi-domain effects. Overall, the results highlight how cyberattacks extend beyond technical boundaries to affect real-world entities and environments (Table 2).

CSVSS-Based Evaluation While CVSS focuses on the three technical dimensions (Confidentiality, Integrity, Availability), it does not account for the broader societal and physical impact of an attack; CSVSS extends it by introducing the Social Impact dimension built on the Entity and Place pillars, enabling a more comprehensive evaluation.

Table 2 reports the two scoring systems across the analyzed scenarios. CSVSS never scores an attack below its CVSS value and raises the severity wherever the social impact is non-negligible, capturing cascading effects that the technical score alone overlooks. For IT-layer attacks, and the Cross-Site Scripting case in particular, the assessment rises when societal reach is taken into account.

Across all scenarios, CSVSS yields a higher severity than CVSS whenever the social impact is non-negligible, in line with the model's objective. The increase is

Table 2. Comparison between CVSS and CSVSS scores (left) and attack impact using CIAEP dimensions (right).

Scenario	CVSS	CSVSS
DoS	7.5	8.2
XSS	8.9	9.8
Ransomware	10	10
Kurtlar	9.4	10

Attack	C	I	A	E	P
DoS	None	None	High	Low	Low
XSS	High	High	None	Low	Low
Ransomware	High	High	High	High	High
Kurtlar	High	High	High	High	High

most visible in the Cross-Site Scripting (8.9 to 9.8) and Denial of Service (7.5 to 8.2) scenarios. For Kurtlar, the social dimension pushes the score to the final step (9.4 to 10), whereas for ransomware, the technical severity is already maximal (CVSS = 10), so the social dimension confirms the top-tier rating. The result is *holistic*: the social domain is more than the sum of its parts, which is why the recalibrated, non-linear impact function of Eq. (4) is preferable to a plain additive aggregation.

LLM-based Cyber Risk Analysis An LLM is integrated into the system to produce dynamic, automated evaluations: through purpose-built prompts, the model autonomously determines the impact of an attack, drastically reducing the time needed to assess the results. The model adopted is Mistral 7B [16], a 7-billion-parameter model that achieves state-of-the-art performance among base models with fewer than 13 billion parameters, making it well-suited for automated, context-aware analysis. The following analysis – in the appendix – presents the results of applying LLM-based cyber-social assessment across multiple attack scenarios within the Digital Twin.

7 Conclusions

Several limitations bound the present study. The Digital Twin is deployed on a modest infrastructure and relies on synthetic data, limiting scalability and realism. Moreover, LLM-based analysis remains sensitive to prompt design and non-deterministic outputs, making human validation essential. The proposed aggregation of Entity and Place dimensions prioritizes transparency and reproducibility, although alternative aggregation methods may be explored in future work. Finally, as Digital Twins introduce additional attack surfaces through interactions between physical and virtual environments, securing these feedback loops remains a critical challenge [25]. Future research will focus on validating the framework in real-world environments, particularly within SOC operations and multi-domain contexts [26]. Further developments include the integration of honeypots, Adversarial Machine Learning (AML), and Explainable AI (XAI) to improve resilience against adversarial attacks and enhance the trustworthiness of automated assessments. The adoption of real-time data streams will also enable predictive simulations and support the evolution of the framework toward SOC-scale deployments.

Acknowledgment

This work was partially supported by the following projects: SETH: Security Education and Training Hybrid-Wargame, Avviso "Reti - Sostegno alla ricerca collaborativa" - Codice progetto BM755Y1; CYBER-PREDICT: Cyber vulnerability ranking prediction by prescription, Avviso "Reti - Sostegno alla ricerca collaborativa", - Codice Progetto DUQVKW0; Patto territoriale "Sistema universitario pugliese" – CUP F61B23000370006; "AURIGA-EDICO" (Ecological Digital Conversion), under the Regional Regulation n.17/2014 – PIA (art. 26) – Project code: 4WBHY73. The research was conducted in partnership with the Department of Computer Science, University of Bari Aldo Moro (SERLAB – Software Engineering Research Laboratory), focusing on the development of AI/ML-based tools and quality measurement systems for sustainable digital conversion of business processes; "CA-LCAP" (Low-Code Application Platform), under the Programma Operativo FESR 2014-2020 – Contratti di Programma (practice code 4UP72S1). The research was conducted in partnership with the Department of Computer Science, University of Bari, within the framework of a research and development contract (OR3 – Activities A.3.5 and A.3.6).

References

1. M. Badawy, N. H. Sherief, and A. A. Abdel-Hamid, "Legacy ics cybersecurity assessment using hybrid threat modeling–an oil and gas sector case study," *Applied Sciences*, vol. 14, no. 18, 2024.
2. O. E. Idrissi, A. Mezrioui, and A. Belmekki, "Cyber security challenges and issues of industrial control systems–some security recommendations," in *2019 IEEE International Smart Cities Conference (ISC2)*, pp. 330–335, 2019.
3. P. Mell *et al.*, "The common vulnerability scoring system (cvss) and its applicability to federal agency systems," Aug. 2007. U.S. Department of Commerce.
4. FIRST.Org, Inc., "Common vulnerability scoring system version 4.0: Specification document," 2023. Document Version 1.2. Available online.
5. V. S. Barletta, D. Caivano, C. Catalano, M. de Gemmis, and D. Impedovo, "Cyber social security education," in *Extended Reality* (L. T. De Paolis, P. Arpaia, and M. Sacco, eds.), (Cham), pp. 240–248, Springer Nature Switzerland, 2024.
6. S. A. Varghese, A. Dehlaghi Ghadim, A. Balador, Z. Alimadadi, and P. Papadimitratos, "Digital twin-based intrusion detection for industrial control systems," in *2022 IEEE International Conference on Pervasive Computing and Communications Workshops and other Affiliated Events (PerCom Workshops)*, pp. 611–617, 2022.
7. A. Sayghe, "Digital twin-driven intrusion detection for industrial scada: A cyber-physical case study," *Sensors*, vol. 25, no. 16, 2025.
8. M. El-Hajj, "Leveraging digital twins and intrusion detection systems for enhanced security in iot-based smart city infrastructures," *Electronics*, vol. 13, no. 19, 2024.
9. M. Dietz, D. Schlette, and G. Pernul, "Harnessing digital twin security simulations for systematic cyber threat intelligence," in *2022 IEEE 46th Annual Computers, Software, and Applications Conference (COMPSAC)*, pp. 789–797, 2022.

10. S. Venkatachalapathy, "Strategic utilization of digital twins for examining elastic attack surfaces and replicating attack scenarios for vulnerability analysis on road vehicle components," in *11th SAEINDIA International Mobility Conference (SIIMC 2024)*, SAE Technical Paper, 2024.
11. D. Formby, M. Rad, and R. Beyah, "Lowering the barriers to industrial control system security with GRFICS," in *2018 USENIX Workshop on Advances in Security Education (ASE 18)*, (Baltimore, MD), USENIX Association, Aug. 2018.
12. S. Gulyamov, A. Akhmedov, S. Bazarov, A. Ubaydullaeva, S. Musaev, A. Rodionov, and I. Odilkhujaev, "Using digital twins for modeling and testing cybersecurity scenarios in smart cities," in *2024 6th International Conference on Control Systems, Mathematical Modeling, Automation and Energy Efficiency (SUMMA)*, pp. 655–658, 2024.
13. M. T. Baldassarre, V. S. Barletta, and D. Caivano, "Smart program management in a smart city," in *2018 AEIT International Annual Conference*, pp. 1–6, 2018.
14. Forum of Incident Response and Security Teams (FIRST), *Common Vulnerability Scoring System (CVSS) v4.0 Specification Document*, 2023.
15. S. Jafarikhah, D. Thompson, E. Deans, H. Siadati, and Y. Liu, "From description to score: Can llms quantify vulnerabilities?," 2026.
16. A. Q. Jiang, A. Sablayrolles, A. Mensch, C. Bamford, D. S. Chaplot, D. de las Casas, F. Bressand, G. Lengyel, G. Lample, L. Saulnier, L. R. Lavaud, M.-A. Lachaux, P. Stock, T. L. Scao, T. Lavril, T. Wang, T. Lacroix, and W. E. Sayed, "Mistral 7b," 2023.
17. M. Baruwal Chhetri, S. Tariq, R. Singh, F. Jalalvand, C. Paris, and S. Nepal, "Towards human-ai teaming to mitigate alert fatigue in security operations centres," *ACM Trans. Internet Technol.*, vol. 24, July 2024.
18. A. Mohsin, H. Janicke, A. Ibrahim, I. H. Sarker, and S. Camtepe, "A unified framework for human ai collaboration in security operations centers with trusted autonomy," 2025.
19. X. Etxezarreta, I. Garitano, M. Iturbe, and U. Zurutuza, "On the use of minicps for conducting rigorous security experiments in software-defined industrial control systems," *Wireless Networks*, vol. 30, no. 9, pp. 7377–7390, 2024.
20. A. Somma, V. Casola, A. R. Cavalli, A. De Benedictis, W. Mallouli, and V. E. Valdés, "A cyber digital twin framework to support cyber-physical systems security," in *2023 IEEE Smart World Congress (SWC)*, pp. 1–10, 2023.
21. N. Kayastha, D. Niyato, P. Wang, and E. Hossain, *Communication networks in smart grid: an architectural view*, p. 3–33. Cambridge University Press, 2012.
22. A. Amiri, G. Steindl, I. Gorton, S. Hollerer, W. Kastner, and T. Sauter, "Integrated safety and security by design in the it/ot convergence of industrial systems: A graph-based approach," in *2024 IEEE International Conference on Software Services Engineering (SSE)*, pp. 123–129, 2024.
23. OWASP Foundation, "Owasp top 10: 2025," 2025.
24. T. R. Wanasinghe, L. Wroblewski, B. K. Petersen, R. G. Gosine, L. A. James, O. De Silva, G. K. I. Mann, and P. J. Warrian, "Digital twin for the oil and gas industry: Overview, research trends, opportunities, and challenges," *IEEE Access*, vol. 8, pp. 104175–104197, 2020.
25. H. Mun, K. Han, E. Damiani, H. K. Yeun, T.-Y. Kim, L. Martino, and C. Y. Yeun, "A comprehensive survey on digital twin: Focusing on security threats and requirements," *IEEE Access*, vol. 13, pp. 73362–73390, 2025.
26. V. S. Barletta, M. Calvano, and A. Sciacovelli, "Cyber social security in multidomain operations," in *2024 IEEE International Workshop on Technologies for Defense and Security (TechDefense)*, pp. 41–46, 2024.